

Narrativa Explicativa del Marco QGM + PRAGMATIC para Indicadores CWE

Hay muchas formas de inventarse métricas, pero solo unas pocas de dormir tranquilo después. El matrimonio de conveniencia entre QGM y PRAGMATIC es precisamente un intento de que los indicadores sobre CWE no nazcan de una iluminación momentánea en un comité, sino de una cadena lógica desde los objetivos de país hasta los bits de los sistemas de ticketing. [web:16][web:17][web:21][web:26]

QGM nos obliga a hacer las preguntas en el orden correcto: primero definir qué queremos lograr (Goal), luego qué necesitamos saber para ver si avanzamos (Question) y, solo al final, qué podemos medir (Metric). [web:18][web:24] Dicho de otra manera, cada métrica debe poder justificar su existencia señalando a una pregunta y a una meta que la reclama. Si no puede, es sospechosa de ser puro decorado estadístico.

En el contexto de CWE, las metas nacionales suenan a grandes titulares: reducir la prevalencia de debilidades críticas, mejorar los tiempos de remediación, integrar el lenguaje de debilidades en la regulación y elevar la capacidad del tejido productivo para tratar con ellas. [web:9][web:14][web:22][web:28] A partir de ahí, las preguntas se vuelven más incómodas: ¿qué porcentaje de nuestras vulnerabilidades se explica por unas pocas CWE del Top 25?, ¿qué sectores están especialmente dominados por fallos de autenticación o de validación de entrada?, ¿cuánto tardamos realmente en corregir un XSS o un desbordamiento de buffer? [web:28][web:27]

Las métricas vienen después y, a ser posible, sin fuegos artificiales. Por ejemplo, el porcentaje de vulnerabilidades mapeadas a CWE del Top 25, el tiempo medio de remediación por tipo de debilidad o la proporción de incidentes críticos atribuibles a un puñado de CWE. [web:28][web:2][web:9] Son números bastante prosaicos, pero tienen la virtud de hablar el mismo idioma que los informes de MITRE, ENISA y compañía. Y eso, en un mundo de taxonomías cruzadas, ya es casi poesía aplicada. [web:22][web:14]

Ahora bien, QGM nos dice qué medir, pero no si lo que medimos es una buena idea. Ahí entra PRAGMATIC, que hace de crítico literario de las métricas. Una métrica puede ser bastante precisa y aun así no servir para tomar decisiones; puede ser baratísima de obtener, pero totalmente irrelevante; o puede ser muy relevante, pero demasiado cara y lenta como para ser útil. [web:21][web:26] Evaluar cada métrica con los nueve criterios (Predictiva, Relevante, Accionable, Genuina, Significativa, Precisa, Oportuna, Independiente y Rentable) no garantiza la perfección, pero al menos obliga a justificar por qué seguimos recogiendo cada dato.

Por ejemplo, el tiempo medio de remediación por CWE prioritaria puntúa alto en predicción, relevancia y capacidad de acción, porque dice mucho sobre la ventana de exposición y permite ajustar procesos y SLAs. [web:9][web:14] Pero su independencia es más discutible: quien es evaluado por ese número tiene incentivos para “cerrar” tickets de forma poco estricta. Una métrica con buena puntuación global PRAGMATIC no es necesariamente cómoda de publicar, pero suele ser un mejor espejo de la realidad.

El resultado de combinar GQM y PRAGMATIC sobre el universo CWE es un mapa ordenado:

- Cada gráfico de un supuesto cuadro de mando nacional tiene una genealogía clara (G–Q–M).
- Cada métrica ha pasado un pequeño juicio de utilidad y honestidad (PRAGMATIC).
- Y, sobre todo, el conjunto se puede debatir sin que nadie tenga que recurrir a la fe para defender sus indicadores favoritos.

Este enfoque también ayuda a navegar el delicado equilibrio entre lo técnico y lo político. Los objetivos nacionales se formulan en términos inteligibles para responsables públicos (“disminuir la concentración del riesgo en unas pocas debilidades”, “reducir la ventana de exposición”, “alinear regulación y práctica internacional”), mientras que las métricas se anclan en datos técnicos muy concretos (CWE, CVE, CVSS, KEV). [web:9][web:14][web:22][web:28] GQM sirve de traductor simultáneo entre esos dos mundos; PRAGMATIC, de filtro de ruido.

Finalmente, la narrativa es también un recordatorio de modestia: ningún índice compuesto (IGM o similar) va a capturar toda la complejidad de la ciberseguridad nacional. [web:24][web:29] Pero un conjunto razonablemente pequeño de métricas bien justificadas y vigiladas puede ayudar a que las decisiones sobre inversiones, regulación y prioridades de actuación se alejen un poco del instinto y se acerquen, aunque sea tímidamente, a la evidencia. El resto seguirá siendo política, negociación y, por supuesto, azar: pero al menos el componente medible no será una excusa, sino una brújula.